

DOCUMENTO 4: SGSI ISO 27001 + POLÍTICAS DLP

SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI)

Conforme a ISO/IEC 27001:2022

4Geeks Academy

Versión: 1.0
Fecha de Emisión: 31 de enero de 2026
Próxima Revisión: 31 de enero de 2027
Clasificación: CONFIDENCIAL - USO INTERNO
Aprobado por: [CEO / Junta Directiva]

CONTROL DE VERSIONES

Versión	Fecha	Autor	Cambios
1.0	31/01/2026	Equipo de Seguridad	Documento inicial

ÍNDICE

- 1. Contexto de la Organización
- 2. Liderazgo
- 3. Planificación
- 4. Soporte
- 5. Operación
- 6. Evaluación del Desempeño
- 7. Mejora Continua
- 8. Declaración de Aplicabilidad (Anexo A)
- 9. Políticas DLP (Prevención de Pérdida de Datos)
- 10. Procedimientos Operativos
- 11. Auditoría y Revisión por la Dirección

1. CONTEXTO DE LA ORGANIZACIÓN

1.1 Comprensión de la Organización y su Contexto

4Geeks Academy es una institución educativa especializada en formación tecnológica, que ofrece cursos intensivos (bootcamps) y programas de desarrollo profesional en áreas como desarrollo de software, ciencia de datos, ciberseguridad y otras disciplinas tecnológicas.

Modelo de Negocio:

- Formación presencial y online
- Programas de 12-24 semanas
- Plataforma de aprendizaje digital propietaria
- Servicios de colocación laboral (job placement)

Activos de Información Críticos:

- 1. Datos de Estudiantes:**
 - Información personal identificable (PII)
 - Expedientes académicos
 - Datos de pago
- 2. Propiedad Intelectual:**
 - Materiales educativos propietarios
 - Código fuente de plataforma educativa
 - Metodologías pedagógicas
- 3. Infraestructura Tecnológica:**
 - Plataforma LMS (Learning Management System)
 - Sitio web corporativo
 - Bases de datos de estudiantes
 - Sistemas de gestión interna

1.2 Necesidades y Expectativas de las Partes Interesadas

Parte Interesada	Necesidades/Expectativas	Requisitos de Seguridad
Estudiantes	Protección de sus datos personales	Cumplimiento RGPD, confidencialidad
Empleados	Ambiente de trabajo seguro	Protección de datos laborales
Socios Comerciales	Confianza en manejo de datos compartidos	Contratos de confidencialidad, controles técnicos
Reguladores	Cumplimiento normativo	RGPD, LOPD-GDD, normativas educativas

Accionistas	Protección de reputación e inversión	Gestión de riesgos, continuidad de negocio
Proveedores de Servicios	Requisitos de seguridad claros	Evaluación de terceros, SLAs

1.3 Alcance del SGSI

Límites del SGSI:

Incluido:

- Todos los sistemas de información que soportan operaciones educativas
- Plataforma LMS
- Sitio web corporativo (www.4geeksacademy.com)
- Bases de datos de estudiantes y académicas
- Sistemas de gestión administrativa (CRM, ERP)
- Infraestructura de red corporativa
- Servicios cloud utilizados (AWS, Google Workspace, etc.)
- Personal de 4Geeks Academy (empleados, contratistas)

Excluido:

- Sistemas de terceros fuera de control directo (pero se gestionan vía contratos)
- Dispositivos personales de estudiantes (BYOD gestionado vía políticas)

Ubicaciones Físicas:

- Oficinas centrales: [Dirección]
- Centros de formación: [Listado de ubicaciones]
- Servicios cloud: [Regiones AWS/Azure utilizadas]

1.4 Requisitos Legales y Regulatorios

Normativas Aplicables:

1. **Reglamento General de Protección de Datos (RGPD) - Reglamento (UE) 2016/679**
 - Protección de datos personales de ciudadanos UE
 - Derechos de los interesados (acceso, rectificación, supresión, portabilidad)
2. **Ley Orgánica 3/2018 de Protección de Datos Personales y garantía de los derechos digitales (LOPD-GDD)**
 - Adaptación española del RGPD
 - Derechos digitales específicos
3. **Ley de Servicios de la Sociedad de la Información (LSSI) - Ley 34/2002**
 - Obligaciones de información en sitio web

- Política de cookies
- Comunicaciones comerciales
- 4. **Normativas Educativas:**
 - Legislación sectorial aplicable según jurisdicción
 - Requisitos de protección de datos de menores (si aplica)
- 5. **Normativas de Ciberseguridad:**
 - ENS (Esquema Nacional de Seguridad) - si se colabora con administraciones públicas
 - Directiva NIS (si aplicable por tamaño/sector)

2. LIDERAZGO

2.1 Liderazgo y Compromiso de la Dirección

Declaración de Compromiso de la Alta Dirección:

La Alta Dirección de 4Geeks Academy se compromete a:

1. Garantizar que el SGSI logre sus resultados previstos
2. Asegurar la disponibilidad de recursos necesarios
3. Comunicar la importancia de la seguridad de la información
4. Apoyar al personal en sus contribuciones a la eficacia del SGSI
5. Promover la mejora continua
6. Respalidar otros roles de gestión relevantes

Firmado:

[Nombre del CEO]

CEO - 4Geeks Academy

Fecha: [DD/MM/YYYY]

2.2 Política de Seguridad de la Información

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN - 4GEEKS ACADEMY

Propósito:

Establecer el marco de gobierno y los principios fundamentales para la protección de los activos de información de 4Geeks Academy, garantizando la confidencialidad, integridad y disponibilidad de la información.

Principios Fundamentales:

1. **Confidencialidad:**
 - La información solo será accesible por personas autorizadas
 - Se implementarán controles de acceso basados en roles (RBAC)
 - Datos sensibles serán cifrados en tránsito y en reposo
2. **Integridad:**

- La información será precisa, completa y no será modificada sin autorización
 - Se implementarán mecanismos de verificación de integridad
 - Cambios en sistemas críticos seguirán procesos de gestión de cambios
3. **Disponibilidad:**
- Los sistemas y datos estarán disponibles cuando sean necesarios
 - Objetivo de disponibilidad: 99.5% para sistemas críticos
 - Implementación de backups y planes de continuidad
4. **Cumplimiento Legal:**
- Cumplimiento estricto de RGPD y normativas aplicables
 - Respeto a derechos de propiedad intelectual
 - Cooperación con autoridades cuando sea legalmente requerido
5. **Mejora Continua:**
- Revisión periódica de controles de seguridad
 - Lecciones aprendidas de incidentes
 - Adaptación a amenazas emergentes

Responsabilidades:

- **Alta Dirección:** Aprobar políticas, asignar recursos, revisión anual
- **CIO/CISO:** Implementar y mantener el SGSI, reportar a dirección
- **Responsables de Área:** Cumplir políticas, reportar incidentes
- **Todos los Empleados:** Proteger activos de información, reportar incidentes

Excepciones:

Cualquier excepción a esta política debe:

- Ser solicitada por escrito con justificación de negocio
- Ser evaluada por el CISO en términos de riesgo
- Ser aprobada por el CIO o CEO
- Tener fecha de vencimiento y ser revisada periódicamente

Revisión:

Esta política será revisada anualmente o tras cambios significativos en el negocio o panorama de amenazas.

Aprobación:

[Nombre del CEO]
CEO - 4Geeks Academy
Fecha: [DD/MM/YYYY]

2.3 Roles, Responsabilidades y Autoridades Organizacionales

Estructura de Gobierno de Seguridad:

[CEO / Junta Directiva]



Roles Clave:

1. CISO (Chief Information Security Officer)

- **Responsabilidades:**
 - Diseñar, implementar y mantener el SGSI
 - Gestión de riesgos de seguridad de la información
 - Supervisar programa de concienciación
 - Coordinar respuesta a incidentes
 - Reportar métricas de seguridad a la dirección
- **Autoridad:**
 - Aprobar políticas y estándares de seguridad
 - Rechazar proyectos con riesgos inaceptables
 - Ordenar auditorías de seguridad
 - Acceso directo a CEO para temas críticos

2. DPO (Data Protection Officer)

- **Responsabilidades:**
 - Supervisar cumplimiento de RGPD
 - Asesorar sobre evaluaciones de impacto (DPIA)
 - Punto de contacto con AEPD
 - Gestionar derechos de los interesados
- **Independencia:**
 - Reporta directamente a Alta Dirección
 - No puede ser despedido por realizar sus funciones
 - Sin conflicto de intereses (no puede ser IT Manager)

3. Responsables de Activos de Información (Information Asset Owners)

- **Responsabilidades:**
 - Clasificar información bajo su responsabilidad
 - Autorizar accesos a datos
 - Garantizar cumplimiento de políticas DLP

- Revisar logs de acceso periódicamente

4. Comité de Seguridad de la Información

- **Composición:**
 - CIO/CISO (Chair)
 - DPO
 - Representante de IT
 - Representante Legal
 - Representantes de unidades de negocio
 - **Frecuencia:** Trimestral
 - **Funciones:**
 - Revisar estado del SGSI
 - Aprobar inversiones en seguridad
 - Evaluar riesgos emergentes
 - Aprobar excepciones a políticas
-

3. PLANIFICACIÓN

3.1 Gestión de Riesgos

3.1.1 Metodología de Evaluación de Riesgos

Marco Adoptado: ISO 31000 + ISO 27005

Proceso de Gestión de Riesgos:

1. Identificación de Activos



2. Identificación de Amenazas y Vulnerabilidades



3. Evaluación de Impacto y Probabilidad



4. Cálculo de Riesgo (Riesgo = Impacto × Probabilidad)



5. Tratamiento de Riesgos



6. Monitoreo y Revisión Continua

Criterios de Evaluación:

Impacto:

Nivel	Descripción	Impacto Financiero	Impacto Reputacional	Impacto Legal
1 - Muy Bajo	Insignificante	< 1,000€	Sin impacto	Sin consecuencias
2 - Bajo	Menor	1,000-10,000€	Impacto local	Advertencia
3 - Medio	Moderado	10,000-50,000€	Impacto nacional	Multas menores
4 - Alto	Significativo	50,000-500,000€	Cobertura mediática	Multas significativas
5 - Muy Alto	Catastrófico	> 500,000€	Crisis reputacional	Sanciones graves RGPD

Probabilidad:

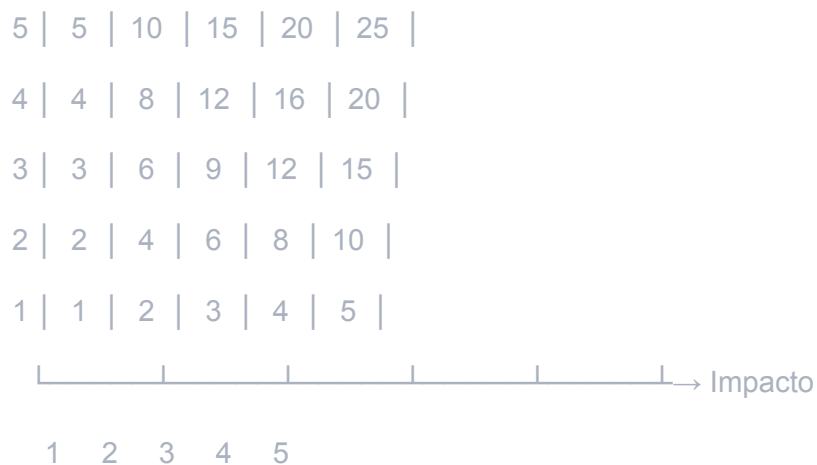
Nivel	Descripción	Frecuencia Estimada
1 - Muy Baja	Improbable en los próximos 5 años	< 5% anual
2 - Baja	Podría ocurrir en 5 años	5-20% anual
3 - Media	Podría ocurrir en 1-2 años	20-50% anual

4 - Alta	Probablemente ocurrirá este año	50-80% anual
-----------------	---------------------------------	--------------

5 - Muy Alta	Casi certeza de ocurrencia	> 80% anual
---------------------	----------------------------	-------------

Matriz de Riesgo:

Probabilidad $\uparrow$



Nivel de Riesgo:

- Bajo (1-4): Aceptable con monitoreo
- Medio (5-9): Requiere controles adicionales
- Alto (10-15): Acción correctiva prioritaria
- Crítico (16-25): Acción inmediata requerida

3.1.2 Registro de Riesgos

Formato del Registro:

ID	Activo	Amenaza	Vulnerabilidad	Impacto	Prob.	Riesgo	Tratamiento	Responsable	Estado
----	--------	---------	----------------	---------	-------	--------	-------------	-------------	--------

R-001	BD Estudiantes	Acceso no autorizado	Credenciales débiles	5	3	15	Mitigar	CISO	Abierto
-------	----------------	----------------------	----------------------	---	---	----	---------	------	---------

Principales Riesgos Identificados (Top 10):

R-001: Compromiso de Base de Datos de Estudiantes

- **Activo:** Base de datos MySQL - Estudiantes
- **Amenaza:** Acceso no autorizado por atacante externo
- **Vulnerabilidad:** Credenciales débiles, falta de MFA
- **Impacto:** 5 (Muy Alto) - Violación RGPD masiva
- **Probabilidad:** 3 (Media)
- **Riesgo Inherente:** 15 (Alto) ●
- **Tratamiento:** Mitigar
 - Implementar contraseñas robustas (20+ caracteres)
 - MFA para acceso a BD
 - Monitoreo de accesos anómalos
 - Cifrado de datos en reposo
- **Riesgo Residual Objetivo:** 6 (Medio) ●
- **Responsable:** DBA + CISO
- **Fecha Límite:** 28/02/2026

R-002: Ransomware en Servidores de Producción

- **Activo:** Servidores web y aplicaciones
- **Amenaza:** Ataque de ransomware
- **Vulnerabilidad:** Falta de segmentación de red, backups no testeados
- **Impacto:** 5 (Muy Alto) - Interrupción completa del negocio
- **Probabilidad:** 3 (Media)
- **Riesgo Inherente:** 15 (Alto) ●
- **Tratamiento:** Mitigar
 - EDR en todos los servidores
 - Segmentación de red (DMZ)
 - Backups offline 3-2-1
 - Plan de recuperación de desastres testeado
- **Riesgo Residual Objetivo:** 5 (Bajo) ●
- **Responsable:** IT Manager + CISO
- **Fecha Límite:** 31/03/2026

R-003: Pérdida de Propiedad Intelectual (Materiales Educativos)

- **Activo:** Currículo y materiales propietarios
- **Amenaza:** Exfiltración por empleado o atacante
- **Vulnerabilidad:** Falta de DLP, permisos excesivos

- **Impacto:** 4 (Alto) - Pérdida de ventaja competitiva
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 8 (Medio) ●
- **Tratamiento:** Mitigar
 - Implementar sistema DLP
 - Clasificación de documentos (Confidencial/Interno/Público)
 - Watermarking de materiales
 - Monitoreo de transferencias masivas
- **Riesgo Residual Objetivo:** 4 (Bajo) ●
- **Responsable:** CISO + Director Académico
- **Fecha Límite:** 30/04/2026

R-004: Phishing Exitoso contra Empleados

- **Activo:** Credenciales de empleados
- **Amenaza:** Campaña de phishing dirigido
- **Vulnerabilidad:** Falta de concienciación, sin MFA universal
- **Impacto:** 3 (Medio)
- **Probabilidad:** 4 (Alta)
- **Riesgo Inherente:** 12 (Alto) ●
- **Tratamiento:** Mitigar
 - Programa de formación continua
 - Simulaciones de phishing mensuales
 - MFA obligatorio para todos los servicios
 - Filtros avanzados de email (sandbox)
- **Riesgo Residual Objetivo:** 4 (Bajo) ●
- **Responsable:** RRHH + CISO
- **Fecha Límite:** 15/02/2026

R-005: Fallo de Proveedor Cloud Crítico

- **Activo:** Plataforma LMS en cloud
- **Amenaza:** Interrupción prolongada del proveedor cloud
- **Vulnerabilidad:** Dependencia de un único proveedor, sin plan de contingencia
- **Impacto:** 4 (Alto) - Interrupción de clases
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 8 (Medio) ●
- **Tratamiento:** Aceptar con Mitigación Parcial
 - SLA robusto con proveedor (99.9% uptime)
 - Plan de comunicación a estudiantes
 - Contenido offline disponible
 - (No multi-cloud por costos, pero evaluar anualmente)
- **Riesgo Residual:** 6 (Medio) ●
- **Responsable:** CIO
- **Fecha Límite:** 31/03/2026 (revisión de SLA)

R-006: Insider Threat - Empleado Malicioso

- **Activo:** Datos sensibles, propiedad intelectual

- **Amenaza:** Empleado con intención maliciosa
- **Vulnerabilidad:** Privilegios excesivos, monitoreo insuficiente
- **Impacto:** 4 (Alto)
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 8 (Medio) ●
- **Tratamiento:** Mitigar
 - Principio de mínimo privilegio
 - Segregación de funciones
 - Monitoreo de actividades privilegiadas
 - Proceso de off-boarding estricto
 - Background checks en contratación
- **Riesgo Residual Objetivo:** 4 (Bajo) ●
- **Responsable:** RRHH + CISO
- **Fecha Límite:** 30/04/2026

R-007: DDoS que Afecta Disponibilidad de Sitio Web

- **Activo:** Sitio web corporativo, plataforma de inscripciones
- **Amenaza:** Ataque DDoS volumétrico
- **Vulnerabilidad:** Sin protección anti-DDoS dedicada
- **Impacto:** 3 (Medio) - Pérdida de inscripciones
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 6 (Medio) ●
- **Tratamiento:** Transferir
 - Contratar Cloudflare Pro o similar
 - WAF con protección DDoS incluida
 - Monitoreo de disponibilidad 24/7
- **Riesgo Residual:** 2 (Bajo) ●
- **Responsable:** IT Manager
- **Fecha Límite:** 28/02/2026

R-008: Vulnerabilidad Crítica 0-day en Software Utilizado

- **Activo:** Sistemas operativos, aplicaciones
- **Amenaza:** Explotación de 0-day antes del parche
- **Vulnerabilidad:** No hay parche disponible
- **Impacto:** 5 (Muy Alto)
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 10 (Alto) ●
- **Tratamiento:** Aceptar con Plan de Respuesta
 - Suscripción a threat intelligence
 - Plan de respuesta a 0-days
 - Virtual patching con WAF/IPS cuando sea posible
 - Segmentación de red para limitar impacto
- **Riesgo Residual:** 8 (Medio) ●
- **Responsable:** CISO
- **Fecha Límite:** Continuo

R-009: Incumplimiento RGPD - Multa de AEPD

- **Activo:** Reputación, finanzas
- **Amenaza:** Auditoría de AEPD encuentra incumplimientos
- **Vulnerabilidad:** Procesos de privacidad no completamente documentados
- **Impacto:** 4 (Alto) - Multa + reputación
- **Probabilidad:** 2 (Baja)
- **Riesgo Inherente:** 8 (Medio) ●
- **Tratamiento:** Mitigar
 - Completar registro de actividades de tratamiento
 - DPIA para tratamientos de alto riesgo
 - Políticas de retención de datos
 - Formación en RGPD a todo el personal
 - Auditoría interna de cumplimiento
- **Riesgo Residual Objetivo:** 3 (Bajo) ●
- **Responsable:** DPO + Legal
- **Fecha Límite:** 31/03/2026

R-010: Pérdida de Backups por Desastre Físico

- **Activo:** Backups de datos críticos
- **Amenaza:** Incendio, inundación en datacenter
- **Vulnerabilidad:** Backups solo en una ubicación física
- **Impacto:** 5 (Muy Alto) - Pérdida total de datos
- **Probabilidad:** 1 (Muy Baja)
- **Riesgo Inherente:** 5 (Medio) ●
- **Tratamiento:** Mitigar
 - Estrategia 3-2-1: 3 copias, 2 medios, 1 off-site
 - Backups cloud en región geográfica diferente
 - Testeo trimestral de restauración
- **Riesgo Residual Objetivo:** 2 (Bajo) ●
- **Responsable:** IT Manager
- **Fecha Límite:** 29/02/2026

3.1.3 Opciones de Tratamiento de Riesgos

1. Mitigar (Reducir):

- Implementar controles de seguridad para reducir probabilidad o impacto
- Opción más común
- Ejemplo: Implementar MFA para reducir riesgo de compromiso de credenciales

2. Transferir:

- Compartir el riesgo con terceros (seguros, outsourcing)
- Ejemplo: Ciber-seguro para cubrir costos de brechas de datos

3. Evitar:

- Eliminar la actividad que genera el riesgo
- Ejemplo: No almacenar datos de tarjetas de crédito (usar pasarela de pago externa)

4. Aceptar:

- Reconocer el riesgo sin acción adicional (típicamente para riesgos bajos)
- Requiere aprobación explícita de la dirección
- Debe documentarse la justificación

3.2 Objetivos de Seguridad de la Información

Objetivos SMART para 2026:

ID	Objetivo	Medición	Responsable	Fecha Límite
O 1	Reducir incidentes de seguridad de Nivel 3+ en 50% vs 2025	# incidentes/trimestre	CISO	31/12/2026
O 2	Alcanzar 95% de sistemas críticos con MFA implementado	% sistemas con MFA	IT Manager	31/03/2026
O 3	Lograr 100% de empleados formados en concienciación de seguridad	% empleados formados	RRHH + CISO	30/06/2026
O 4	Reducir MTDD (Mean Time To Detect) a < 1 hora	Tiempo promedio	CSIRT	30/09/2026
O 5	Implementar DLP en 100% de endpoints	% endpoints con DLP	CISO	30/06/2026
O 6	Completar al menos 2 auditorías de seguridad externas	# auditorías	CISO	31/12/2026

O 7	Lograr 99.5% de disponibilidad de plataforma LMS	% uptime	IT Manager	31/12/2026
--------	---	----------	------------	------------

4. SOPORTE

4.1 Recursos

Presupuesto de Seguridad de la Información 2026:

Categoría	Inversión Anual	Justificación
Personal	180,000€	CISO, 2 Analistas de Seguridad
Herramientas	60,000€	SIEM, EDR, DLP, WAF
Formación	15,000€	Certificaciones, cursos especializados
Auditorías Externas	25,000€	Pentesting anual, auditoría ISO 27001
Ciber-Seguro	12,000€	Prima anual
Contingencias	8,000€	Gastos imprevistos
TOTAL	300,000€	~3% de presupuesto IT estimado

4.2 Competencia

Matriz de Competencias Requeridas:

Rol	Competencias Técnicas	Certificaciones Deseables	Formación Continua
CISO	Gestión de riesgos, arquitectura de seguridad, cumplimiento	CISSP, CISM, ISO 27001 Lead Implementer	40h/año
Analista de Seguridad	SIEM, análisis de malware, respuesta a incidentes	GCIH, GCIA, CEH	32h/año
DPO	RGPD, privacidad, análisis legal	CIPP/E, CIPM	24h/año
Administradores IT	Hardening de sistemas, gestión de parches	Linux+, RHCSA, AWS Certified	24h/año

4.3 Concienciación

Programa de Concienciación en Seguridad:

Objetivo: Convertir a todos los empleados en primera línea de defensa.

Componentes:

1. Formación Inicial (Onboarding):

- Duración: 2 horas
- Contenido:
 - Políticas de seguridad de 4Geeks
 - Uso aceptable de recursos IT
 - Reconocimiento de phishing
 - Manejo de datos sensibles
 - Reporte de incidentes
- Obligatoria para todos los nuevos empleados

2. Formación Anual Obligatoria:

- Duración: 3 horas (online + presencial)
- Contenido actualizado anualmente según amenazas emergentes
- Certificado de finalización requerido
- Seguimiento de cumplimiento por RRHH

3. Simulaciones de Phishing:

- Frecuencia: Mensual
- Proveedor: [KnowBe4 / Cofense / similar]
- Métricas:
 - % de clicks en enlaces maliciosos
 - % de usuarios que reportan correctamente
 - Objetivo: < 5% de click rate al final de 2026

4. Newsletter de Seguridad:

- Frecuencia: Mensual
- Contenido:
 - Amenazas recientes
 - Consejos prácticos
 - Incidentes (anonimizados) y lecciones aprendidas
 - Quiz corto con premio para fomentar lectura

5. Campañas Temáticas:

- Cybersecurity Awareness Month (Octubre)
- Data Privacy Day (28 de Enero)
- Campañas específicas tras incidentes significativos

6. Material de Referencia:

- Pósters en oficinas
- Screensavers con tips de seguridad
- Guías rápidas (password security, remote work security)

4.4 Comunicación

Plan de Comunicación Interna de Seguridad:

Audiencia	Canal	Frecuencia	Contenido
Toda la Organización	Email + Intranet	Mensual	Newsletter, políticas actualizadas
Alta Dirección	Presentación ejecutiva	Trimestral	Métricas de seguridad, riesgos principales

IT y Técnicos	Email + Slack #security	Semanal	Alertas técnicas, vulnerabilidades
Nuevos Empleados	Presencial	Al incorporarse	Formación de onboarding
Tras Incidentes	Email urgente	Según necesidad	Información, acciones requeridas

4.5 Información Documentada

Documentación del SGSI:

Documentos Obligatorios ISO 27001:

- Alcance del SGSI (Sección 1.3)
- Política de Seguridad (Sección 2.2)
- Evaluación de Riesgos (Sección 3.1)
- Declaración de Aplicabilidad (Sección 8)
- Objetivos de Seguridad (Sección 3.2)
- Evidencia de competencias (registros de formación)
- Resultados de monitoreo y medición
- Programa de auditoría interna
- Resultados de auditorías
- Resultados de revisión por la dirección

Repositorio Documental:

- Ubicación: SharePoint - Carpeta SGSI (acceso restringido)
- Control de versiones: Obligatorio
- Revisión: Anual o tras cambios significativos
- Aprobación: Requerida por CISO para documentos de nivel 1-2

Clasificación de Documentos:

- **Nivel 1 - Público:** Accesible para cualquiera
- **Nivel 2 - Interno:** Solo empleados de 4Geeks
- **Nivel 3 - Confidencial:** Solo personal autorizado
- **Nivel 4 - Restringido:** Máxima sensibilidad (ej. registros de riesgos)

5. OPERACIÓN

5.1 Planificación y Control Operacional

Procesos Operativos de Seguridad:

1. Gestión de Cambios:

- Todo cambio en sistemas de producción requiere:
 - Solicitud formal (Change Request)
 - Evaluación de impacto en seguridad por CISO
 - Aprobación del Change Advisory Board (CAB)
 - Plan de rollback
 - Documentación de la configuración final
- Cambios de emergencia permitidos con aprobación retrospectiva (dentro de 24h)

2. Gestión de Configuraciones:

- Baseline de configuración segura para:
 - Servidores Linux (CIS Benchmark)
 - Servicios cloud (AWS Well-Architected Framework)
 - Aplicaciones web (OWASP guidelines)
- Herramienta de gestión de configuraciones: Ansible / Terraform
- Auditorías de configuración: Trimestrales

3. Gestión de Vulnerabilidades:

Escaneo Automatizado (Semanal)



Clasificación por Criticidad



Crítico: Parche en 7 días

Alto: Parche en 30 días

Medio: Parche en 90 días

Bajo: Evaluar en próxima ventana de mantenimiento



Verificación de Remediación

4. Gestión de Parches:

- Servidores críticos: Ventana de mantenimiento mensual
- Parches de seguridad críticos: Aplicación en < 72h con aprobación de CIO
- Entorno de prueba (staging) obligatorio antes de producción

- Backups completos antes de aplicar parches

5. Gestión de Backups:

- Estrategia 3-2-1:
 - 3 copias de datos
 - 2 tipos de medios diferentes (disco + cloud)
 - 1 copia off-site (región geográfica diferente)
- Frecuencia:
 - Datos críticos (BD): Diario (incremental) + Semanal (completo)
 - Archivos de aplicaciones: Semanal
 - Configuraciones: Tras cada cambio
- Testeo de restauración: Trimestral (mínimo)
- Retención:
 - Diarios: 7 días
 - Semanales: 4 semanas
 - Mensuales: 12 meses
 - Anuales: 7 años (para cumplimiento)

5.2 Evaluación de Riesgos de Seguridad de la Información

Frecuencia de Evaluaciones:

- **Completa:** Anualmente (Q4)
- **Revisiones ligeras:** Trimestrales
- **Ad-hoc:** Tras incidentes significativos, cambios mayores en infraestructura

Proceso:

1. Actualizar inventario de activos
2. Revisar amenazas y vulnerabilidades (nuevas CVEs, threat intel)
3. Re-evaluar impacto y probabilidad
4. Actualizar registro de riesgos
5. Revisar tratamientos de riesgo
6. Presentar a Comité de Seguridad
7. Obtener aprobación de Alta Dirección para riesgos residuales

6. EVALUACIÓN DEL DESEMPEÑO

6.1 Seguimiento, Medición, Análisis y Evaluación

KPIs del SGSI:

KPI	Objetivo 2026	Frecuencia	Responsable
Incidentes de Seguridad Nivel 3+	< 5/año	Mensual	CISO
MTTD (Mean Time To Detect)	< 1 hora	Mensual	CSIRT
MTTR (Mean Time To Respond)	< 4 horas	Mensual	CSIRT
Vulnerabilidades Críticas Abiertas	0	Semanal	IT Manager
% Sistemas con Parches Actualizados	> 95%	Mensual	IT Manager
% Empleados Formados en Seguridad	100%	Trimestral	RRHH
Click Rate en Phishing Simulado	< 5%	Mensual	CISO
Disponibilidad de Sistemas Críticos	99.5%	Mensual	IT Manager
Cumplimiento de Políticas (Auditoría)	100%	Semestral	Auditor Interno
Riesgos Altos/Críticos Abiertos	< 3	Mensual	CISO

Dashboard de Seguridad:

- Herramienta: Power BI / Tableau
- Actualización: Automática (diaria)
- Acceso: Alta Dirección, CISO, Comité de Seguridad
- Contenido: Visualización de todos los KPIs + tendencias

6.2 Auditoría Interna

Programa de Auditoría Interna:

Frecuencia: Semestral (mínimo)

Alcance Rotativo:

- Semestre 1: Controles técnicos (A.8, A.12, A.13)
- Semestre 2: Controles organizativos (A.5, A.6, A.7) + Cumplimiento RGPD

Auditor:

- Independiente del área auditada
- Formación en ISO 27001
- Certificación deseable: ISO 27001 Lead Auditor

Proceso:

1. Planificación (definir alcance, criterios)
2. Notificación previa (2 semanas)
3. Revisión documental
4. Entrevistas con responsables
5. Verificación de evidencias (logs, configuraciones, etc.)
6. Informe de hallazgos (conformidades, no conformidades, observaciones)
7. Plan de acción correctiva
8. Seguimiento de cierre de hallazgos

Criterios de No Conformidad:

- **Mayor:** Ausencia o fallo total de un control crítico requerido
- **Menor:** Control implementado pero con deficiencias
- **Observación:** Mejora recomendada, no incumplimiento

6.3 Revisión por la Dirección

Frecuencia: Trimestral (mínimo), con revisión anual completa

Participantes:

- CEO
- CIO/CISO
- DPO
- Director de RRHH
- Director Financiero
- Director de Operaciones

Agenda (Revisión Trimestral):

1. Estado de acciones de la revisión anterior

2. KPIs del trimestre vs objetivos
3. Incidentes de seguridad significativos
4. Resultados de auditorías internas/externas
5. Cambios en el contexto interno/externo (nuevas amenazas, regulaciones)
6. Cumplimiento de objetivos de seguridad
7. Retroalimentación de partes interesadas
8. Resultados de evaluación de riesgos
9. Oportunidades de mejora continua
10. Necesidad de recursos adicionales

Outputs de la Revisión:

- Decisiones sobre mejoras del SGSI
- Decisiones sobre cambios en objetivos de seguridad
- Decisiones sobre necesidades de recursos
- Acciones para abordar riesgos y oportunidades

Documentación:

- Acta de reunión con decisiones tomadas
 - Asignación de responsables y fechas límite
 - Seguimiento en próxima revisión
-

7. MEJORA CONTINUA

7.1 No Conformidades y Acciones Correctivas

Proceso de Gestión de No Conformidades:

Identificación de No Conformidad

(Auditoría, Incidente, Revisión, etc.)



Registro en Sistema de Gestión

(Asignar ID, Severidad, Responsable)



Análisis de Causa Raíz

(5 Whys, Ishikawa, etc.)



Plan de Acción Correctiva

(Acciones, Responsables, Plazos)



Implementación



Verificación de Eficacia



Cierre (o Re-apertura si no efectiva)

Ejemplo - Registro de No Conformidad:

ID	Descripción	Severidad	Causa Raíz	Acción Correctiva	Responsable	Fecha Límite	Estado
NC-001	Backup no testeado en 6 meses	Mayor	Falta de procedimiento documentado	1) Crear procedimiento de testeo trimestral 2) Programar testeo inmediato	IT Manager	28/02/2026	Abierto

7.2 Mejora Continua

Fuentes de Mejora:

1. Resultados de auditorías internas y externas
2. Análisis de incidentes de seguridad (lecciones aprendidas)
3. Cambios en amenazas y vulnerabilidades
4. Feedback de empleados y partes interesadas
5. Nuevas tecnologías y mejores prácticas
6. Cambios regulatorios

Ciclo PDCA (Plan-Do-Check-Act):

PLAN (Planificar)

- Identificar oportunidad de mejora
- Establecer objetivos
- Planificar acciones



DO (Hacer)

- Implementar acciones planificadas
- Pequeña escala (piloto) cuando sea posible



CHECK (Verificar)

- Monitorear resultados
- Comparar contra objetivos
- Identificar desviaciones



ACT (Actuar)

- Si es exitoso: Estandarizar y desplegar
- Si no: Ajustar y repetir ciclo

Reuniones de Mejora:

- Mensual: Equipo de seguridad revisa oportunidades de mejora
- Trimestral: Presentación a Comité de Seguridad
- Anual: Revisión estratégica de mejoras implementadas

8. DECLARACIÓN DE APLICABILIDAD (ANEXO A ISO 27001)

Controles del Anexo A - Estado de Implementación

Leyenda:

-  Implementado
-  Implementación Parcial

-  No Implementado
- N/A No Aplica

A.5 - Políticas de Seguridad de la Información

Control	Descripción	Estado	Justificación / Comentarios
A.5.1	Políticas para la seguridad de la información		Política de seguridad aprobada por CEO, revisión anual
A.5.2	Revisión de las políticas para la seguridad de la información		Revisión anual programada en Q4

A.6 - Organización de la Seguridad de la Información

Control	Descripción	Estado	Justificación / Comentarios
A.6.1	Roles y responsabilidades internas		CISO, DPO, y roles definidos en Sección 2.3
A.6.2	Segregación de funciones		Implementado parcialmente; mejoras planificadas con más personal
A.6.3	Contacto con autoridades		Relaciones establecidas con Policía, AEPD, INCIBE
A.6.4	Contacto con grupos de interés especial		Pendiente membresía en ISAC sectorial
A.6.5	Seguridad de la información en la gestión de proyectos		Proceso definido, pero no siempre seguido; necesita refuerzo

A.7 - Seguridad de los Recursos Humanos

Control	Descripción	Estado	Justificación / Comentarios
A.7.1	Selección		Background checks solo para roles sensibles; extender a todos
A.7.2	Términos y condiciones de empleo		Contratos incluyen cláusulas de confidencialidad y uso aceptable
A.7.3	Concienciación, educación y formación		Programa completo descrito en Sección 4.3
A.7.4	Proceso disciplinario		Proceso definido en manual de RRHH
A.7.5	Responsabilidades al terminar o cambiar empleo		Checklist de off-boarding implementado

A.8 - Gestión de Activos

Control	Descripción	Estado	Justificación / Comentarios
A.8.1	Inventario de activos		Inventario existe pero requiere actualización y automatización
A.8.2	Propiedad de los activos		Responsables asignados, pero necesita formalización
A.8.3	Uso aceptable de los activos		Política de uso aceptable firmada por todos los empleados

A.8.4	Devolución de activos	✓	Parte del proceso de off-boarding
A.8.5	Clasificación de la información	●	Sistema definido (Público/Interno/Confidencial/Restringido), implementación en curso
A.8.6	Etiquetado de la información	✗	Pendiente: Implementar watermarking y metadata
A.8.7	Manejo de activos	●	Procedimientos definidos, formación pendiente
A.8.8	Gestión de medios	✓	Procedimiento de borrado seguro implementado
A.8.9	Gestión de medios en tránsito	●	Cifrado obligatorio, pero sin herramienta centralizada
A.8.10	Eliminación de medios	✓	Contrato con empresa certificada de destrucción segura

A.9 - Control de Acceso

Contro l	Descripción	Estad o	Justificación / Comentarios
A.9.1	Política de control de acceso	✓	Política basada en roles (RBAC) implementada
A.9.2	Gestión de acceso de usuarios	●	Proceso definido, revisiones trimestrales planificadas

A.9.3	Responsabilidades del usuario	✓	Incluido en formación de onboarding y AUP
A.9.4	Control de acceso a sistemas y aplicaciones	●	MFA implementado en servicios críticos, pendiente universalizar

A.10 - Criptografía

Control	Descripción	Estado	Justificación / Comentarios
A.10.1	Controles criptográficos	●	TLS para tránsito, cifrado en reposo en BD críticas, pendiente generalizar

A.11 - Seguridad Física y del Entorno

Control	Descripción	Estado	Justificación / Comentarios
A.11.1	Áreas seguras	✓	Datacenter con acceso controlado por tarjeta + PIN
A.11.2	Controles físicos de entrada	✓	Recepción, cámaras, registro de visitantes
A.11.3	Seguridad de oficinas, despachos e instalaciones	✓	Política de escritorio limpio, pantallas con bloqueo automático
A.11.4	Protección contra amenazas externas y ambientales	✓	Sistemas anti-incendios, UPS, climatización redundante en datacenter

A.11.5	El trabajo en áreas seguras		Política de acceso a datacenter, log de accesos
--------	-----------------------------	---	---

A.11.6	Áreas de carga y descarga	N/A	No aplicable a 4Geeks Academy
--------	---------------------------	-----	-------------------------------

A.12 - Seguridad de las Operaciones

Contro l	Descripción	Estad o	Justificación / Comentarios
A.12.1	Procedimientos operacionales documentados		Runbooks para operaciones críticas, ampliación en curso
A.12.2	Gestión de cambios		Proceso CAB implementado
A.12.3	Gestión de capacidad		Monitoreo básico, sin planificación formal de capacidad
A.12.4	Separación de entornos de desarrollo, prueba y producción		Entornos segregados en cloud
A.12.5	Protección contra malware		EDR en todos los endpoints y servidores
A.12.6	Gestión de vulnerabilidades técnicas		Escaneo semanal, proceso de parcheo definido
A.12.7	Consideraciones sobre auditorías de sistemas de información		Auditorías en entornos no productivos cuando sea posible

A.13 - Seguridad de las Comunicaciones

Contro l	Descripción	Estad o	Justificación / Comentarios
A.13.1	Gestión de la seguridad de redes	✓	Segmentación de red, firewall perimetral y por host
A.13.2	Transferencia de información	●	TLS obligatorio, falta DLP completo para controlar transferencias masivas

A.14 - Adquisición, Desarrollo y Mantenimiento de Sistemas

Contro l	Descripción	Estad o	Justificación / Comentarios
A.14.1	Requisitos de seguridad de los sistemas de información	●	Requisitos definidos para nuevos proyectos, no siempre formalizados
A.14.2	Seguridad en los procesos de desarrollo y soporte	●	Code reviews para cambios críticos, pendiente implementar SAST/DAST
A.14.3	Datos de prueba	✓	Datos de producción anonimizados para testing

A.15 - Relaciones con los Proveedores

Contro l	Descripción	Estad o	Justificación / Comentarios
A.15.1	Seguridad de la información en las relaciones con proveedores	●	Evaluación básica de proveedores críticos, falta framework formal
A.15.2	Gestión de la prestación de servicios de proveedores	●	SLAs existen, pero revisión de seguridad no sistemática

A.16 - Gestión de Incidentes de Seguridad de la Información

Contro l	Descripción	Estad o	Justificación / Comentarios
A.16.1	Gestión de incidentes y mejoras en la seguridad de la información	✓	Plan de Respuesta a Incidentes completo (Documento 3)

A.17 - Aspectos de Seguridad de la Información en la Gestión de la Continuidad del Negocio

Contro l	Descripción	Estad o	Justificación / Comentarios
A.17.1	Continuidad de la seguridad de la información	●	BCP existe, pero necesita testeo formal
A.17.2	Redundancias	●	Backups 3-2-1 implementados, falta redundancia de sistemas en tiempo real

A.18 - Cumplimiento

Contro l	Descripción	Estad o	Justificación / Comentarios
A.18.1	Cumplimiento de requisitos legales y contractuales	✓	Revisión legal anual, DPO monitorea cumplimiento RGPD
A.18.2	Revisión de la seguridad de la información	✓	Auditorías internas semestrales, auditoría externa anual planificada

Resumen de Aplicabilidad

Estado	Controles	Porcentaje
✅ Implementado	42	56%
⚠️ Parcial	28	37%
❌ No Implementado	4	5%
N/A No Aplica	1	1%
TOTAL	75	100%

Plan de Cierre de Brechas:

- Controles no implementados: Prioridad para Q1-Q2 2026
- Controles parciales: Plan de mejora progresiva durante 2026
- Objetivo: ≥ 90% de controles completamente implementados para 31/12/2026

9. POLÍTICAS DLP (PREVENCIÓN DE PÉRDIDA DE DATOS)

9.1 Política General de DLP

Propósito:

Prevenir la pérdida, fuga o exfiltración no autorizada de información sensible de 4Geeks Academy, protegiendo la confidencialidad de datos de estudiantes, propiedad intelectual y secretos comerciales.

Alcance:

Todos los datos clasificados como "Confidencial" o "Restringido", en cualquier estado:

- **Datos en Reposo:** Almacenados en servidores, bases de datos, dispositivos
- **Datos en Uso:** Accedidos por aplicaciones o usuarios

- **Datos en Tránsito:** Transferidos por red (email, FTP, HTTP, etc.)

9.2 Clasificación de Datos

Sistema de Clasificación de 4 Niveles:

Nivel	Descripción	Ejemplos	Controles Requeridos
PÚBLICO	Información destinada a divulgación pública	Material marketing, blog, cursos publicados	Ninguno específico
INTERNO	Información interna sin sensibilidad	Políticas generales, organigramas	Acceso solo empleados
CONFIDENCIAL	Información sensible para el negocio	Datos de estudiantes, contratos, financiero	Acceso basado en roles + cifrado + DLP
RESTRINGIDO	Información altamente sensible	Credenciales de sistemas, IP crítica	Acceso nominativo + cifrado + DLP + auditoría

Responsabilidad de Clasificación:

- **Data Owners:** Responsables de clasificar datos bajo su responsabilidad
- **Revisión:** Anual o tras cambios significativos
- **Marcado:** Obligatorio para Confidencial y Restringido (watermarks, headers en emails)

9.3 Controles Técnicos DLP

Herramientas Implementadas/Planificadas:

1. DLP para Endpoints (Data Loss Prevention):

- **Solución:** [Microsoft Purview / Symantec DLP / Digital Guardian]
- **Funcionalidad:**
 - Monitoreo de clipboard (copiar/pegar)
 - Control de dispositivos USB (bloquear/permitir selectivamente)
 - Escaneo de archivos copiados a medios extraíbles

- Captura de pantalla bloqueada en aplicaciones sensibles
- **Estado:** 🟡 Piloto en departamentos críticos, despliegue completo Q2 2026

2. DLP para Email:

- **Solución:** Integrado en Microsoft 365 / Google Workspace
- **Reglas:**
 - Bloqueo de envío de archivos con clasificación "Restringido" fuera de dominio corporativo
 - Cifrado automático (S/MIME o TLS) para emails con datos "Confidenciales"
 - Alerta a supervisor si se detectan > 100 registros de estudiantes en un email
 - Cuarentena de emails con keywords: "password", "contraseña", "credencial" + datos sensibles
- **Estado:** ✅ Implementado

3. DLP para Web y Cloud:

- **Solución:** CASB (Cloud Access Security Broker) - Microsoft Defender for Cloud Apps
- **Funcionalidad:**
 - Monitoreo de uploads a servicios cloud no autorizados
 - Control de compartición externa en OneDrive/Google Drive
 - Prevención de paste de información sensible en webmail externo
 - Shadowriesgos IT discovery
- **Estado:** 🟡 Planificado para Q3 2026

4. DLP para Bases de Datos:

- **Enfoque:** Database Activity Monitoring (DAM)
- **Controles:**
 - Monitoreo de queries que retornan > 1000 registros
 - Alerta de exportaciones masivas (CSV, SQL dump)
 - Bloqueo de acceso directo a BD desde fuera de red corporativa
- **Estado:** 🟡 Implementación parcial, mejoras planificadas

9.4 Políticas Específicas por Tipo de Dato

9.4.1 Datos Personales de Estudiantes (PII)

Datos Incluidos:

- Nombre completo, DNI/Pasaporte
- Dirección, teléfono, email
- Datos de pago (si almacenados)
- Expediente académico

Controles Obligatorios:

- Clasificación: **CONFIDENCIAL**

- Acceso: Solo personal con necesidad (profesores del alumno, admin, soporte)
- Cifrado: AES-256 en reposo, TLS 1.3 en tránsito
- Retención: Máximo 7 años tras finalización de curso (por requisitos legales)
- DLP: Bloqueo de envío masivo fuera de dominio corporativo
- Auditoría: Log de todos los accesos a BD de estudiantes

Incumplimiento:

- Notificación obligatoria a DPO
- Posible violación RGPD → notificación a AEPD en 72h

9.4.2 Propiedad Intelectual (Materiales Educativos)

Datos Incluidos:

- Currículo de cursos
- Videos de clases
- Ejercicios y proyectos
- Código fuente de plataforma LMS

Controles Obligatorios:

- Clasificación: **CONFIDENCIAL** o **RESTRINGIDO** (según criticidad)
- Watermarking: Todos los PDFs y videos deben incluir marca de agua con ID de usuario
- DLP: Bloqueo de uploads a servicios cloud personales (Dropbox, Google Drive personal)
- Acceso: Profesores solo pueden descargar materiales de sus cursos asignados
- Monitoreo: Alertas de descargas masivas (> 50 archivos en 24h)

Incumplimiento:

- Investigación interna
- Posible acción disciplinaria
- Si es fuga externa: Acción legal

9.4.3 Credenciales y Secretos

Datos Incluidos:

- Contraseñas de sistemas
- Claves API
- Tokens de acceso
- Certificados privados

Controles Obligatorios:

- Clasificación: **RESTRINGIDO**
- Almacenamiento: Solo en Password Manager corporativo (1Password / LastPass Enterprise)

- Prohibido: Almacenar en archivos de texto, emails, documentos
- Rotación: Trimestral para credenciales críticas
- DLP: Escaneo de repositories (GitHub, GitLab) para detectar credenciales hardcodeadas
- Auditoría: Log de todos los accesos a credenciales

Herramienta Recomendada: Secret scanning con GitGuardian o similar

9.5 Monitoreo y Respuesta a Eventos DLP

Clasificación de Eventos DLP:

Severidad	Descripción	Acción Automática	Acción Manual
Informativa	Uso permitido pero notable	Log	Revisión semanal
Advertencia	Uso sospechoso pero no bloqueado	Log + Notificación a usuario	Revisión diaria
Bloqueado	Acción bloqueada por política DLP	Bloqueo + Log + Alerta a CISO	Investigación inmediata

Respuesta a Incidente DLP:

Evento DLP Detectado



Clasificar Severidad



Si Bloqueado → Investigación Inmediata:

- Confirmar legitimidad del uso
- Si es legítimo: Excepción temporal con aprobación
- Si no es legítimo: Incidente de seguridad (activar IRP)



Si Advertencia → Contacto con Usuario:

- Explicar política violada
- Solicitar justificación
- Formación adicional si es necesario



Documentación en Sistema de Gestión de Incidentes

9.6 Excepciones a Políticas DLP

Proceso de Solicitud de Excepción:

- 1. Solicitud Formal:**
 - Formulario: [Link a SharePoint]
 - Información requerida:
 - Justificación de negocio
 - Datos/sistemas afectados
 - Duración necesaria
 - Controles compensatorios propuestos
- 2. Evaluación:**
 - DPO: Evalúa impacto en privacidad
 - CISO: Evalúa riesgo de seguridad
 - Data Owner: Aprueba desde perspectiva de negocio
- 3. Aprobación:**
 - Excepciones temporales (< 30 días): CISO
 - Excepciones prolongadas (30-90 días): CISO + CIO
 - Excepciones permanentes: Comité de Seguridad
- 4. Implementación y Seguimiento:**
 - Configuración técnica de excepción en herramienta DLP
 - Fecha de vencimiento automática
 - Revisión mensual de excepciones activas

Registro de Excepciones:

- Todas las excepciones documentadas
- Revisadas trimestralmente
- Revocadas si ya no son necesarias

9.7 Formación y Concienciación en DLP

Contenidos de Formación:

Para Todos los Empleados:

- Sistema de clasificación de datos
- Cómo marcar documentos correctamente
- Qué hacer si se bloquea una acción DLP

- Consecuencias del incumplimiento

Para Roles con Acceso a Datos Sensibles:

- Formación específica en manejo de PII
- Procedimientos de anonimización
- Uso correcto de herramientas de cifrado
- Compartición segura de información

Para Desarrolladores:

- Secrets management
- Evitar hardcodear credenciales
- Uso de .gitignore apropiado
- Secret scanning en pipelines CI/CD

Frecuencia:

- Onboarding: Obligatorio
- Anual: Refresher para todos
- Tras incidentes: Formación específica para afectados

9.8 Métricas DLP

KPIs de DLP:

Métrica	Objetivo	Medición
Eventos DLP - Bloqueados	< 50/mes	Mensual
Eventos DLP - Falsos Positivos	< 20% del total	Mensual
Tiempo de Respuesta a Evento Crítico	< 2 horas	Por incidente
% Datos Clasificados	100% de datos sensibles	Trimestral
Excepciones DLP Activas	< 10 simultáneas	Mensual

Reporting:

- Dashboard mensual para CISO
 - Informe trimestral para Comité de Seguridad
 - Tendencias y análisis de patrones
-

10. PROCEDIMIENTOS OPERATIVOS

10.1 Procedimiento de Gestión de Incidentes

Ver Documento 3 - Plan de Respuesta a Incidentes

10.2 Procedimiento de Gestión de Cambios

Objetivo: Garantizar que los cambios en sistemas de información se realizan de manera controlada y segura.

Alcance: Todos los cambios en:

- Infraestructura (servidores, redes, cloud)
- Aplicaciones de producción
- Configuraciones de seguridad

Proceso:

1. Solicitud de Cambio (Change Request - CR):

- Formulario: ServiceNow / JIRA Service Desk
- Información requerida:
 - Descripción del cambio
 - Justificación de negocio
 - Sistemas afectados
 - Impacto estimado (usuarios, servicios)
 - Ventana de implementación propuesta
 - Plan de rollback
 - Evaluación de riesgo

2. Evaluación de Seguridad:

- CISO revisa CR desde perspectiva de seguridad
- Checklist:
 - ¿Introduce nuevas vulnerabilidades?
 - ¿Afecta controles de seguridad existentes?
 - ¿Requiere actualización de políticas?
 - ¿Cumple con baseline de configuración segura?
- Aprobación/rechazo/solicitud de modificaciones

3. Aprobación por CAB (Change Advisory Board):

- Composición: CIO (chair), CISO, IT Manager, representante de negocio
- Frecuencia: Semanal

- Decide: Aprobar / Rechazar / Diferir
- Prioriza cambios en conflicto
- 4. **Implementación:**
 - Ejecutado por equipo técnico
 - Siguiendo procedimiento documentado
 - En ventana de mantenimiento aprobada
 - Con backup completo previo
- 5. **Verificación Post-Cambio:**
 - Validación funcional
 - Validación de seguridad (escaneo de vulnerabilidades si aplica)
 - Actualización de documentación (configuraciones, diagramas)
- 6. **Cierre:**
 - CR marcado como "Cerrado - Exitoso" o "Cerrado - Revertido"
 - Post-mortem si hubo problemas

Cambios de Emergencia:

- Pueden implementarse sin aprobación previa de CAB
- Requieren aprobación verbal de CIO + CISO
- Debe generarse CR retrospectivo dentro de 24h
- Revisado en próxima reunión de CAB

10.3 Procedimiento de Gestión de Accesos

Objetivo: Controlar quién tiene acceso a qué sistemas y datos.

Principios:

- **Least Privilege:** Mínimo acceso necesario para realizar funciones
- **Need to Know:** Acceso solo a información necesaria
- **Segregación de Funciones:** Separar roles críticos
- **Revisión Periódica:** Validar que accesos siguen siendo apropiados

Proceso de Concesión de Acceso:

1. **Solicitud:**
 - Formulario en portal de IT
 - Aprobador: Manager del solicitante
 - Información: Sistema, nivel de acceso, justificación, duración
2. **Aprobación:**
 - Manager: Aprueba necesidad de negocio
 - Data Owner: Aprueba acceso a datos específicos
 - CISO: Aprueba accesos privilegiados (admin, root)
3. **Provisión:**
 - IT implementa el acceso
 - Notificación al usuario
 - Documentación en sistema de gestión de identidades
4. **Revisión Periódica:**
 - Trimestral: Managers revisan accesos de su equipo

- Anual: Data Owners revisan accesos a sistemas críticos
- Accesos no confirmados → Desactivados automáticamente

5. Revocación:

- Inmediata: Tras terminación de empleo
- Programada: Accesos temporales con fecha de expiración
- Ad-hoc: Cambio de rol, ya no necesario

Accesos Privilegiados (Administradores):

- **Doble Aprobación:** Manager + CISO
- **MFA Obligatorio:** Siempre
- **Jump Server:** Acceso a producción solo vía bastion host
- **Auditoría:** Todos los comandos ejecutados loguea dos
- **Just-In-Time:** Privilegios elevados solo cuando se necesitan, por tiempo limitado

10.4 Procedimiento de Gestión de Vulnerabilidades

Objetivo: Identificar, evaluar y remediar vulnerabilidades en tiempo apropiado.

Ciclo de Gestión:

Escaneo Automatizado

(Semanal - Qualys/Nessus)



Correlación con Threat Intelligence



Clasificación por Criticidad



Asignación a Responsable



Remediación o Mitigación



Verificación



Cierre o Escalamiento

SLAs de Remediación:

CVSS Score	Criticidad	Plazo de Remediación	Acción
9.0-10.0	Crítica	7 días	Parche o mitigación inmediata
7.0-8.9	Alta	30 días	Planificar parche en próxima ventana
4.0-6.9	Media	90 días	Incluir en mantenimiento trimestral
0.1-3.9	Baja	180 días o próxima actualización mayor	Evaluar necesidad

Excepciones:

- Vulnerabilidades sin parche disponible: Aplicar controles compensatorios (WAF rules, network segmentation)
- Sistemas legacy end-of-life: Plan de migración o aislamiento
- Riesgo de negocio en parcheo: Aprobar excepción con fecha de revisión

Vulnerabilidades Críticas - Proceso Acelerado:

1. Detección (escaneo o alerta de vendor)
2. Notificación inmediata a CISO + IT Manager
3. Evaluación de impacto (< 4 horas)
4. Decisión: Parche emergencia / Mitigación temporal / Aislamiento
5. Implementación (< 24-48 horas)
6. Comunicación a stakeholders

11. AUDITORÍA Y REVISIÓN POR LA DIRECCIÓN

11.1 Programa de Auditoría Interna

Objetivo: Evaluación independiente del cumplimiento del SGSI.

Frecuencia: Semestral (mínimo)

Alcance Anual:

- Todos los controles del Anexo A al menos una vez al año
- Rotación de áreas cada semestre

Equipo Auditor:

- Auditor Líder: Certificado ISO 27001 Lead Auditor
- Auditores: Formados en ISO 27001
- Independencia: No pueden auditar áreas bajo su responsabilidad

Plan de Auditoría 2026:

Semestr e	Alcance	Fechas	Auditor
S1 2026	Controles A.8-A.14 (Técnicos) + Cumplimiento RGD	Febrero-Marzo	[Nombre]
S2 2026	Controles A.5-A.7, A.15-A.18 (Organizativos)	Agosto-Septiemb re	[Nombre]

Proceso de Auditoría:

- 1. Planificación (2 semanas antes):**
 - Notificar a áreas auditadas
 - Solicitar documentación
 - Preparar checklist
- 2. Ejecución:**
 - Reunión de apertura
 - Entrevistas
 - Revisión documental
 - Verificación técnica (muestreo de configuraciones, logs)
 - Reunión de cierre
- 3. Informe:**
 - No conformidades (mayores/menores)
 - Observaciones
 - Buenas prácticas identificadas
 - Plazo: 2 semanas tras finalización
- 4. Seguimiento:**
 - Plan de acción correctiva (30 días para mayores, 90 para menores)
 - Verificación de cierre de hallazgos
 - Reporte a Comité de Seguridad

11.2 Auditorías Externas

Objetivo: Validación independiente por terceros.

Tipos:

1. Auditoría de Certificación ISO 27001:

- Frecuencia: Anual (tras certificación inicial)
- Organismo: Acreditado por ENAC u organismo equivalente
- Alcance: Todo el SGSI
- Resultado: Certificado ISO 27001 (válido 3 años con auditorías anuales)
- Planificado: Q4 2026 (auditoría inicial)

2. Pentesting Externo:

- Frecuencia: Anual
- Proveedor: [Empresa especializada]
- Alcance: Aplicaciones web, infraestructura externa
- Metodología: OWASP Testing Guide, PTES
- Planificado: Q2 2026

3. Auditorías de Cumplimiento:

- RGPD: Según necesidad o requerimiento de AEPD
- Otras normativas: Según aplique

11.3 Revisión por la Dirección

Frecuencia: Trimestral (con revisión anual exhaustiva)

Agenda - Revisión Trimestral:

1. **Seguimiento de Acciones Anteriores** (15 min)
2. **Métricas del Trimestre** (20 min)
 - KPIs vs objetivos
 - Dashboard de seguridad
3. **Incidentes Significativos** (15 min)
 - Resumen de incidentes Nivel 3+
 - Lecciones aprendidas
4. **Resultados de Auditorías** (10 min)
 - Si hubo auditoría en el trimestre
5. **Cambios en Contexto** (10 min)
 - Nuevas amenazas
 - Cambios regulatorios
 - Cambios organizacionales
6. **Estado de Riesgos** (15 min)
 - Riesgos nuevos/modificados
 - Estado de tratamientos

- 7. **Recursos y Presupuesto** (10 min)
 - Ejecución presupuestaria
 - Necesidades adicionales
- 8. **Decisiones y Acciones** (15 min)
 - Qué cambios se aprueban
 - Asignación de responsables

Output:

- Acta de reunión
- Lista de decisiones y acciones con responsables y fechas
- Comunicación a la organización (si aplica)

Revisión Anual (Q4):

- Más exhaustiva (medio día)
- Incluye:
 - Revisión completa de políticas
 - Evaluación de adecuación del SGSI
 - Planificación estratégica para próximo año
 - Aprobación de presupuesto de seguridad
 - Establecimiento de objetivos para próximo año

12. CONTROL DE CAMBIOS Y APROBACIÓN

12.1 Historial de Revisiones

Versión	Fecha	Sección Modificada	Cambios Realizados	Aprobador
1.0	31/01/2026	Todas	Documento inicial	CEO
-	-	-	-	-

12.2 Próximas Revisiones Programadas

- **Revisión Ligera:** Trimestral (actualización de métricas, riesgos)
- **Revisión Completa:** Anual (31/01/2027)
- **Revisión Ad-hoc:** Tras incidentes mayores, cambios regulatorios significativos

12.3 Distribución Controlada

Este documento es CONFIDENCIAL.

Copias Controladas Distribuidas a:

- CEO
- CIO/CISO
- DPO
- Comité de Seguridad
- Auditor Interno
- Auditor Externo (durante auditorías)

Almacenamiento:

- SharePoint - Carpeta SGSI (acceso restringido)
- Versión en papel: Solo en caja fuerte de CEO y CISO